You said:

exec.out
File

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 1m 24s >

ChatGPT said:

MALWARE CONFIRMADO

Veredito: o arquivo `exec.out` é malicioso. A análise estática identificou características de um backdoor para Linux, especificamente compatível com a família **BPFDoor**.

A seguir, apresento as evidências encontradas.

1. Identificação do arquivo

A primeira análise foi feita com ferramentas de identificação de executáveis, sem executar o arquivo.

Propriedade	Resultado
Nome	`exec.out`
Tamanho	31.960 bytes
Formato	ELF
Arquitetura	Linux x86-64
Tipo	Executável PIE
Ligação	Dinâmica
Bibliotecas	libc.so.6
Símbolos	Não removidos (*not stripped*)

Hash SHA-256:

```
521b34e4b170c57fa708956a0cbae7fc67be6dd6cf0f5945067bc1d2e9114f7e
```

O formato ELF é normal para um executável Linux. Portanto, isoladamente, não constitui evidência de malware.

2. Inspeção dos símbolos internos

A tabela de símbolos revelou nomes de funções bastante suspeitos:

```
packet_loop
getshell
shell
set_proc_name
rc4_init
rc4
try_link
logon
mon
```

Esses nomes indicam funcionalidades relacionadas a comunicação de rede, autenticação, criptografia e criação de sessões de shell.

Um achado particularmente relevante foi:

```
Linux.RedMenshenBPFDoor.c
```

Esse nome aparece entre as informações internas de compilação do executável e sugere explicitamente uma implementação de BPFDoor.

Embora um nome de arquivo isolado não prove comportamento malicioso, as funcionalidades identificadas posteriormente confirmam essa suspeita.

3. Análise do comportamento de rede

A função `packet_loop` é uma das partes mais importantes do programa.

A desmontagem revelou chamadas para:

```
socket()
setsockopt()
recvfrom()
```

O programa cria um socket de baixo nível:

- Família: `AF_PACKET`.
- Tipo: `SOCK_RAW`.
- Protocolo: `ETH_P_IP`.

Também utiliza `setsockopt` com a opção `SO_ATTACH_FILTER`, para instalar um filtro BPF no socket.

Isso permite que o programa examine pacotes de rede e selecione aqueles que correspondem aos critérios definidos.

O código também identifica protocolos IP como:

- TCP (6);
- UDP (17);
- ICMP (1).

Interpretação: o programa monitora passivamente o tráfego de rede em busca de pacotes especiais que podem funcionar como comandos para ativar suas funcionalidades ocultas.

Esse comportamento é característico de backdoors acionados por pacotes de rede.

4. Análise da autenticação e criptografia

Foram encontradas duas funções relacionadas à criptografia:

```
rc4_init()
rc4()
```

Elas implementam operações associadas ao algoritmo RC4.

Também foi encontrada a função:

```
logon()
```

Sua implementação utiliza `memcmp()` para comparar os dados recebidos com valores armazenados na configuração interna.

Entre as sequências encontradas estão:

```
justforfun
socket
```

Esses valores são utilizados nas verificações internas de autenticação.

Interpretação: o malware utiliza verificações específicas e mecanismos de criptografia para reconhecer determinados pacotes de ativação, dificultando a identificação de seus comandos por uma inspeção superficial do tráfego.

5. Análise da execução de comandos remotos

Esta é uma das evidências mais fortes.

O executável possui uma função chamada:

```
getshell()
```

Ela prepara comandos do sistema e chama `system()`.

Outra função identificada é:

```
shell()
```

Sua implementação apresenta operações como:

```
fork()
dup2()
execve()
```

Além disso, o código contém referências explícitas a:

```
/bin/sh
```

A combinação dessas operações permite criar um processo de shell e redirecionar sua entrada, saída e saída de erro para uma conexão ou pseudo-terminal.

Isso possibilita que um operador remoto execute comandos no sistema comprometido.

Evidência de backdoor

O programa não se limita a monitorar pacotes: ele possui mecanismos funcionais para fornecer acesso remoto ao shell do sistema.

6. Análise de manipulação do firewall

A desmontagem também revelou comandos associados ao `iptables`, incluindo operações sobre:

```
iptables -t nat
PREROUTING
REDIRECT
--to-ports
```

O malware prepara regras para redirecionamento de tráfego TCP.

Essa funcionalidade pode ser utilizada para facilitar o acesso ao serviço oculto e controlar a comunicação com o shell.

Não se trata de uma operação normalmente necessária para um programa Linux legítimo sem uma finalidade administrativa específica.

7. Análise de ocultação e evasão

Foram encontradas várias técnicas para dificultar a identificação do processo:

Mascaramento do nome do processo

A função `set_proc_name()` modifica o conteúdo associado ao nome do processo.

Entre os nomes utilizados como disfarce estão:

```
/usr/libexec/postfix/master
/sbin/udevd -d
/sbin/mingetty /dev/tty7
/usr/lib/systemd/systemd-journald
```

São nomes que imitam serviços legítimos do Linux.

Execução em segundo plano

A rotina principal utiliza:

```
fork()
setsid()
```

Isso permite separar o processo do terminal original e executar como um processo em segundo plano.

Manipulação de timestamps

A função `setup_time()` utiliza:

```
utimes()
```

Essa operação altera os horários de acesso e modificação de arquivos, podendo dificultar análises forenses.

Arquivo de identificação do processo

O programa também trabalha com:

```
/var/run/haldrun.pid
```

Esses comportamentos reforçam a intenção de permanecer ativo e reduzir sua visibilidade.

8. Correlação das evidências

Característica	Evidência encontrada	Interpretação
Monitoramento de rede	Socket RAW e filtro BPF	Captura seletiva de pacotes
Autenticação	`logon()`	Reconhecimento de comandos especiais
Criptografia	RC4	Proteção dos dados de comunicação
Acesso remoto	`getshell()` e `shell()`	Execução remota de comandos
Comunicação TCP	`connect()`	Estabelecimento de conexão
Manipulação de firewall	`iptables` e `REDIRECT`	Redirecionamento de tráfego
Ocultação	`set_proc_name()` e `prctl()`	Mascaramento do processo
Execução furtiva	`fork()` e `setsid()`	Execução em segundo plano

As evidências são consistentes entre si e demonstram funcionalidades reais de um backdoor, não apenas palavras suspeitas ou referências isoladas.

9. Veredito final

ARQUIVO MALICIOSO

MALWARE

Categoria principal: Backdoor (porta dos fundos).

Família/tipo: BPFDoor para Linux.

Objetivo principal: proporcionar acesso remoto oculto ao sistema, permitindo a execução de comandos por um operador externo.

Confiança da classificação: Muito alta.

Conclusão técnica: o arquivo `exec.out` é um backdoor Linux com capacidade de monitorar pacotes por meio de filtros BPF, reconhecer mensagens especiais, estabelecer comunicação TCP e disponibilizar um shell remoto. Também apresenta mecanismos de ocultação do processo e manipulação de regras de firewall.

Não há evidência de que seja um vírus autorreplicante ou ransomware. Sua classificação principal é **Backdoor / Remote Access Trojan (RAT)**, mais especificamente uma implementação do tipo **BPFDoor**.

Recomendação: não execute o arquivo. Caso ele tenha sido encontrado em um servidor Linux, considere o equipamento potencialmente comprometido e investigue processos disfarçados, regras do `iptables`, conexões de rede e possíveis alterações de arquivos. A análise apresentada foi estática; não foi necessário executar o malware.

You said:

Qual é a categoria principal deste malware?

ChatGPT said:

A categoria principal deste malware é **Backdoor (porta dos fundos)**, especificamente da família **BPFDoor** para Linux.

Sua finalidade é permitir **acesso remoto oculto ao sistema e execução de comandos por um invasor**.